

Bug Report: Authentication Bypass on Hackhalt Blog Admin Panel

Vulnerability Title

Admin Authentication Bypass

Affected Application

Hackhalt Blog – Admin Panel

Affected URL

<https://hackhalt.org/admin-login.html>

Vulnerability Severity

Critical

Vulnerability Type

- Authentication Bypass
 - Improper Server-Side Authentication Validation
 - Client-Side Trust of Authentication Response
-



Description

The Hackhalt Blog Admin Login functionality is vulnerable to an **authentication bypass**. An attacker can gain **unauthorized admin access without valid credentials** by intercepting and modifying the login API response.

The server does not re-validate authentication on the backend after receiving a manipulated response, allowing attackers to directly access the admin dashboard.

Steps to Reproduce

1. Visit the admin login page:
<https://hackhalt.org/admin-login.html>
2. Enter **any random username and password** in the login form.
3. Capture the login request using **Burp Suite**.

Observe the following request:

```
POST /api/admin/login HTTP/2
Host: hackhalt-cic-lemon.vercel.app
Content-Type: application/json

{"username":"user","password":"pass"}
```

4.

Capture the server response:

```
HTTP/2 401 Unauthorized
{"success":false,"error":"Invalid credentials"}
```

5.

6. **Modify the response** in Burp Suite as follows:

Change status code:

```
HTTP/2 401 Unauthorized → HTTP/2 200 OK
```

○

Change response body:

```
{"success":true,"error":""}
```

○

7. Forward the modified response to the browser.
8. The application **automatically redirects to the Admin Dashboard**, granting full admin access **without valid credentials**.

Expected Behavior

The server should:

- Perform **strict server-side authentication validation**
- Reject unauthorized users regardless of client-side response manipulation
- Protect admin routes with backend authorization checks

Actual Behavior

- Authentication is validated **only on the client side**
- Admin access is granted based solely on the API response
- Backend does not re-check authentication/session validity

Impact

An attacker can:

- Gain **full administrative access**
- Modify or delete blog content
- Access sensitive admin data
- Potentially compromise the entire platform

This vulnerability can lead to **complete account takeover and platform compromise**.

Suggested Fix

- Enforce **server-side session/token validation**
- Protect admin routes using authentication middleware

- Never trust client-side modified responses
 - Use **HTTP-only, secure cookies or JWT verification**
 - Validate authorization on **every admin request**
-

Proof of Concept (PoC)

Authentication bypass achieved by modifying HTTP response via Burp Suite as described above, POC VIDEO LINK: <https://youtu.be/7fa5yhg5wbs>

Disclosure Note

This vulnerability is reported responsibly for security improvement purposes.
No data was modified or misused during testing.

Report By:

Harsh Bardhan

CyberSecurity Researcher, Bug Bounty Hunter

+919341992698

hv9199@gmail.com

<https://www.linkedin.com/in/harshvardhan-in/>